

NIST Cybersecurity Framework Gap Analysis Project

Value: 100 pts.

Format: Individual Assignment

Project Overview

You will conduct a cybersecurity gap analysis for "Island Health Partners" (IHP), a fictional healthcare clinic in Honolulu, using the National Institute of Technology (NIST) Cybersecurity Framework. Your task is to evaluate their current security practices against the five CSF functions and provide practical recommendations to improve their cybersecurity posture.

Why NIST Cybersecurity Framework?

The NIST CSF is one of the most widely adopted cybersecurity frameworks in the world because it's:

- **Simple to understand:** Five core functions that make intuitive sense
- **Business-focused:** Connects security to business outcomes
- **Flexible:** Works for organizations of any size or industry
- **Practical:** Provides actionable guidance without overwhelming technical detail

Learning Objectives

By completing this project, you will:

- Apply the NIST Cybersecurity Framework to a real-world scenario
- Understand how cybersecurity connects to business operations
- Identify common security gaps in small organizations
- Develop practical, cost-effective security recommendations
- Experience the role of a cybersecurity consultant

Company Profile: Island Health Partners

Basic Information

Industry: Healthcare (Primary Care Clinic)

Location: Kalihi, Honolulu, Hawaii

Established: 2018

Staff: 25 employees

Annual Revenue: \$3.2 million

Patients Served: ~4,500 active patients

Business Operations

Island Health Partners is a family medicine clinic serving the diverse Kalihi community. They provide primary care, preventive services, and basic urgent care. The clinic prides itself on providing culturally competent care and serves a diverse patient population that includes many individuals who speak Tagalog, Samoan, and Hawaiian, in addition to English.

Services Offered:

- Annual physical exams and wellness visits
- Chronic disease management (diabetes, hypertension)
- Basic urgent care and minor procedures
- Vaccinations and health screenings
- Telemedicine consultations (added during COVID-19)

Business Hours: Monday-Friday 7:30 AM - 6:00 PM, Saturday 8:00 AM - 2:00 PM

Organizational Structure

Leadership Team:

- Dr. Maria Santos (Founder & Medical Director) - 15 years of family medicine experience
- David Kim (Practice Manager) - MBA, handles business operations
- Lisa Wong (Head Nurse) - 20 years of nursing experience, manages clinical staff

Clinical Staff:

- 3 physicians (including Dr. Santos)
- 6 medical assistants
- 4 registered nurses
- 2 nurse practitioners

Administrative Staff:

- 3 front desk/scheduling staff
- 2 billing specialists
- 1 IT support person (part-time contractor)
- 2 cleaning/maintenance staff
- 1 office manager

Facility Description

Main Clinic: 8,500 sq ft space in Kalihi Shopping Center

- 12 examination rooms
- 2 procedure rooms
- Reception area with 20 seats
- Administrative offices
- Small pharmacy for basic medications
- Employee break room and storage areas

Physical Security:

- Basic alarm system (doors/windows)
- Security cameras at main entrance only
- Key-card access for staff (no visitor logging)
- Patient files stored in locked cabinets
- Medication storage in locked pharmacy area

Technology Infrastructure

Current IT Setup:

- 35 desktop computers and 10 laptops
- Basic business internet (50 Mbps download/10 Mbps upload)
- Simple network router with default configuration
- One shared printer in each department
- Basic Wi-Fi network for staff and guest access (same password for both)

Software Systems:

- Electronic Health Records (EHR): "HealthEZ" - cloud-based system
- Practice Management: Integrated with EHR for scheduling/billing
- Email: Standard Gmail business accounts
- File Storage: Mix of local computer storage and Google Drive
- Accounting: QuickBooks Desktop version
- Telemedicine: Zoom for Healthcare

IT Support:

- Part-time contractor (Kevin) comes in twice per week
- No formal IT policies or procedures
- Staff often troubleshoot their own computer problems
- Software updates applied inconsistently

Current Security Practices

What They Do Well:

- All computers require passwords to log in
- EHR system has automatic timeout after 15 minutes
- Staff sign confidentiality agreements
- Physical files are locked in cabinets after hours
- Basic antivirus software on all computers

Current Challenges:

- Many staff share computer passwords for "convenience"
- No formal cybersecurity training program
- USB drives used freely to transfer files
- Personal devices (phones, tablets) used for work tasks
- No backup plan if computer systems fail
- Patient information sometimes emailed without encryption
- Wi-Fi password hasn't been changed in 2 years
- No incident response plan for security breaches

Recent Incidents

Minor Security Events (Past 12 Months):

1. Ransomware pop-up appeared on reception computer (Kevin removed it)
2. Staff member's email account was hacked (password was "password123")
3. Patient complained they received another patient's lab results via email
4. Computer virus infected one workstation via USB drive
5. Power outage caused loss of one day's scheduling data (no backup)

Business Drivers and Concerns

Compliance Requirements:

- HIPAA (Health Insurance Portability and Accountability Act)
- Hawaii state medical privacy laws
- Insurance company security requirements for billing

Business Goals:

- Expand telemedicine services to the neighbor islands
- Implement online patient portal for appointment scheduling
- Add evening and weekend hours
- Achieve recognition as a Patient-Centered Medical Home

Leadership Concerns:

- Dr. Santos worries about patient data being stolen
- David Kim concerned about business disruption from cyber attacks
- Lisa Wong frustrated by slow computers affecting patient care
- Board of directors asking about cybersecurity preparedness

Financial Constraints

Annual IT Budget: \$15,000

- Includes software licenses, hardware maintenance, Kevin's services
 - No dedicated cybersecurity budget currently allocated
 - Willing to invest in security but needs to see clear business value
 - Prefers solutions that improve efficiency while enhancing security
-

Project Requirements

Deliverable: Cybersecurity Gap Analysis Report (4-6 pages)

Your report should be written as if you're a cybersecurity consultant hired by Island Health Partners to assess their current security posture and provide practical recommendations.

Section 1: Executive Summary (1 page)

- Brief overview of Island Health Partners
- Current cybersecurity maturity level (Beginner/Developing/Mature)
- Top 3 security risks that could impact the business
- High-level recommendations and investment required

Section 2: NIST CSF Gap Analysis (2-3 pages)

Evaluate IHP against each of the five NIST CSF functions. For each function, provide:

IDENTIFY:

- What assets (data, systems, people) need protection?
- What are IHP's current practices for identifying cybersecurity risks?
- Gaps: What's missing in their risk identification process?

PROTECT:

- What security controls does IHP currently have in place?
- How do they control access to systems and data?
- Gaps: Where are the protection weaknesses?

DETECT:

- How would IHP know if a cyber attack was happening?
- What monitoring or alerting systems do they have?
- Gaps: What threats might go unnoticed?

RESPOND:

- What would IHP do if they discovered a security incident?
- Who would they call? What steps would they take?
- Gaps: How prepared are they to respond effectively?

RECOVER:

- How would IHP restore operations after a cyber incident?
- Do they have backups and recovery procedures?
- Gaps: What could prevent them from recovering quickly?

Section 3: Practical Recommendations (1-2 pages)

Provide 8-10 specific, actionable recommendations organized by priority:

High Priority (implement within 30 days):

- Focus on the most critical gaps that pose immediate risk
- Should be low-cost and quick to implement

Medium Priority (implement within 90 days):

- Important improvements that require some planning or investment
- Balance cost with security benefit

Low Priority (implement within 12 months):

- Nice-to-have improvements for long-term security posture
- May require significant investment or planning

For each recommendation, include:

- Brief description of the solution
- Why it's needed (what risk it addresses)
- Estimated cost (Free, Under \$1,000, \$1,000-\$5,000, Over \$5,000)
- Implementation difficulty (Easy, Moderate, Complex)

Formatting Requirements

- Use professional business report format
- Include a title page with your name and date
- Use clear headings and subheadings
- Write in clear, non-technical language that clinic management can understand
- Include at least 3 references to course materials or external sources

Grading Rubric

Criterion	Excellent (90-100%)	Proficient (80-89%)	Developing (70-79%)	Inadequate (<70%)
NIST CSF Understanding (30%)	Demonstrates clear understanding of all five CSF functions with accurate application to healthcare scenario	Shows good grasp of CSF with minor gaps in application	Basic understanding evident but some confusion about CSF functions	Limited or incorrect understanding of NIST CSF
Gap Analysis Quality (25%)	Identifies realistic and relevant security gaps with strong justification	Identifies most important gaps with adequate reasoning	Some gaps identified but analysis lacks depth	Few gaps identified or analysis is superficial
Practical Recommendations (25%)	Recommendations are specific, actionable, and well-prioritized with clear cost/benefit analysis	Good recommendations with appropriate prioritization	Recommendations are reasonable but lack detail or clear prioritization	Vague or unrealistic recommendations
Professional Communication (20%)	Report is well-organized, clearly written, and appropriate for business audience	Good organization and writing with minor issues	Adequate communication but some clarity or organization problems	Poor organization, unclear writing, or inappropriate tone

Getting Started: Helpful Hints

Understanding the NIST CSF Functions

Think of the five functions as questions every organization should ask:

- **IDENTIFY:** "What do we need to protect?"
- **PROTECT:** "How do we prevent bad things from happening?"
- **DETECT:** "How do we know if something bad is happening?"
- **RESPOND:** "What do we do when something bad happens?"

- **RECOVER:** "How do we get back to normal after something bad happens?"

Resources You'll Need

- NIST Cybersecurity Framework v1.1 (available at nist.gov/cyberframework)
- Course readings on healthcare cybersecurity
- HIPAA security requirements overview
- Sample gap analysis example (provided on course website)

Common Mistakes to Avoid

- Don't recommend solutions that cost more than IHP's entire annual revenue
- Don't use technical jargon that business managers wouldn't understand
- Don't ignore the healthcare context - remember HIPAA requirements
- Don't forget that IHP is a small business with limited IT expertise

Making It Realistic

Remember that Island Health Partners is:

- A small business with limited resources
- Serving a vulnerable patient population
- Required to comply with HIPAA
- Dependent on technology for daily operations
- Staffed by healthcare professionals, not IT experts

Your recommendations should be practical for their situation, not what a large hospital or tech company might implement.

Submission Instructions

- Submit your report as a PDF through the course LMS
- File name: LastName_FirstName_IHP_Gap_Analysis.pdf
- Due: End of Week 5 (11:59 PM HST Sunday)
- No late submissions without prior authorization or documented emergency.

Academic Integrity

This is an individual assignment. While you may discuss general approaches with classmates, your analysis and recommendations must be your own work. Properly cite any external sources (in APA format) beyond the required course materials.

Questions? Contact the instructor during office hours or via email. Remember, this project simulates real-world consulting work. Think practically and focus on helping Island Health Partners improve their cybersecurity in realistic, affordable ways.